

The Income Tax Credit Phish

Ticket Overview

Ticket Number: SOC-22041

Date/Time Reported: 2023-07-29 / 15:02:00 UTC

Assigned Analyst: Jeremiah Tindana (Contractor at MockingCyber)

Affected Endpoint: N/A

Affected User: phishing@pot (test mailbox)

Incident Summary

On July 29, 2023 at 15:02, the email gateway of a company flagged an email that was destined to one of their employees from a private email address sonyundefinedralph@gmail[.]com. MockingCyber's analyst, Jeremiah Tindana, must review the email and attachment and determine whether this represents a phishing attempt.

NB: The sample phishing email analyzed in this report (sample-1008.eml) is a real-world phishing sample sourced from a public GitHub phishing-sample repository (phishing pot). All investigation, IOC extraction, and analysis is my own independent work. "MockingCyber" is a fictional consultancy name used for realistic case-report formatting, as is the ticket number. The sending company/recipient identity was not disclosed in the source material and is generalized accordingly.

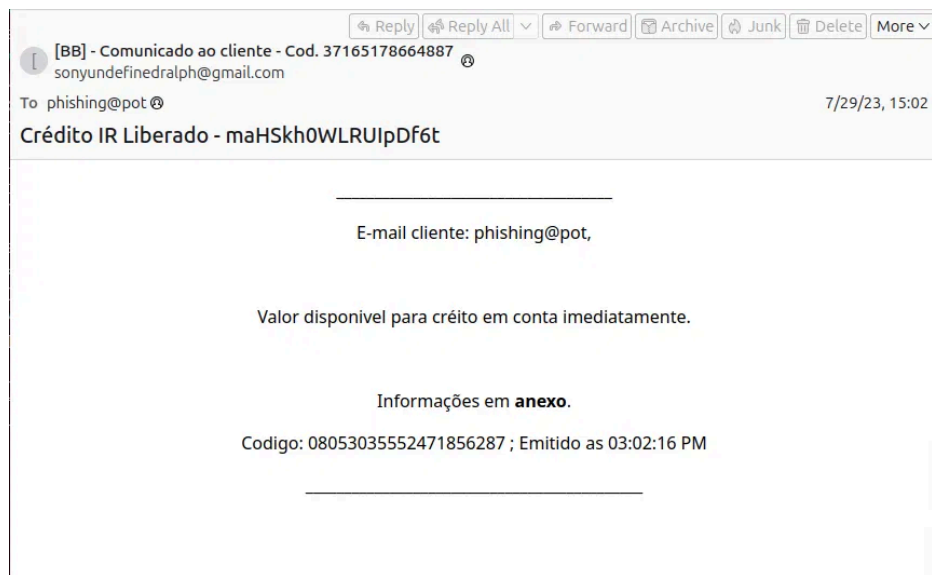
Investigation

I opened the email file (sample-1008.eml) using Thunderbird.

```
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ thunderbird sample-1008.eml
ln: failed to create symbolic link '/home/mockingcyber/snap/thunderbird/1170/.config/dconf/user':
: File exists
Gtk-Message: 20:29:31.470: Not loading module "atk-bridge": The functionality is provided by GTK
natively. Please try to not load it.
[GFX1-]: glxtest: libpci missing
JavaScript warning: https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js,
line 5: Script terminated by timeout at:
sE@https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:3990
ke@https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:4475
Op/<@https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:5:16514
Md@https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:10:6378
I_@https://transcend-cdn.com/cm/d556c3a1-e57c-4bdf-a490-390a1aebf6dd/airgap.js:10:5651

[GFX1-]: RenderCompositorSWGL failed mapping default framebuffer, no dt
```

Picture 1. Thunderbird command to open email



Picture 2. Email opened in Thunderbird

The email subject is displayed with a sender display name of "[BB] - Comunicado ao cliente - Cod. 37165178664887" but an actual sender address of sonyundefinedralph@gmail[.]com which is private free Gmail account with no visible relation to a bank. The mismatch between the display name (impersonating what appears to be a bank, "[BB]") and the actual sending domain is a suspicious indicator here, as it is consistent with a spoofed/impersonation pretext rather than a legitimate bank notification.

×	Income Tax Credit Released - maH5kh0WLRUIpDf6t
Crédito IR Liberado - maH5kh0WLRUIpDf6t	
E-mail cliente: phishing@pot,	Client email: phishing@pot,
Valor disponível para crédito em conta imediatamente.	Amount available for immediate account credit.
Informações em anexo.	Information attached.
Código: 08053035552471856287 ; Emitido as 03:02:16 PM	Code: 08053035552471856287 ; Issued at 03:02:16 PM

Picture 3. Google Translate machine translation of email body

The translated subject reads "Income Tax Credit Released," and the body claims an amount is available for immediate credit to the recipient's account, with details said to be in the attachment, and a code (08053035552471856287) provided at 03:02:16 PM. This aligns with a tax-refund social engineering pretext. It is common for an

attacker to use urgency around a supposed available credit to get the recipient to open the attached PDF.

Using the eioc.py tool, I extracted IPs, URLs, and headers from the email file.

```
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ python3 ../Tools/eioc.py sam
ple-1008.eml
Extracted IP Addresses:
=====
10[.]13[.]181[.]1
209[.]85[.]219[.]43 - Charlotte, North Carolina, US, ISP: AS15169 Google LLC
20[.]161[.]9[.]51 - Boydton, Virginia, US, ISP: AS8075 Microsoft Corporation

Extracted URLs:
=====

Extracted Headers:
=====
Authentication-Results: spf=pass (sender IP is 209.85.219.43)
smtp.mailfrom=gmail.com; dkim=pass (signature was verified)
header.d=gmail.com; dmarc=pass action=none header.from=gmail.com; compauth=pass
reason=100
Return-Path: sonyundefinedralph@gmail.com
Message-ID: <d485b0d32d1d33a95fc07d302aac4ff4@gmail.com>
From: "[BB] - Comunicado ao cliente - Cod. 37165178664887" <sonyundefinedralph@gmail.com>
To: <phishing@pot>
Subject: =?utf-8?B?Q3LDqWRpdG8gSVIgLGlZJhZG8gLSBtYUhTa2gwV0xSVUlw?=?
=?utf-8?B?RGY2dA=?=
Date: Sat, 29 Jul 2023 15:02:16 +0000
X-Sender-IP: 209.85.219.43

Extracted Attachments:
=====
Filename: Fa0ldxfjHYJ.pdf
MD5: 73eb1b98ead1ce54c522ef51d42658bc
SHA1: c3d762618ad889d12fc186b1edb437da6a40917c
SHA256: f90e61278e4a12b1f8a89c662018334335a6fbcd0fdedcb04f44ff16be7cd5b
```

Picture 4. IOC output of eioc.py tool

No URLs were extracted from the email file. Also, a manual scan through the email file using sublime text confirmed no URLs were present. Three IP addresses were extracted:

10.13.181.1, 209.85.219.43 (Sender's IP) and 20.161.9.51 with the last 2 attributed to Google LLC infrastructure in Charlotte, North Carolina and Microsoft Corporation in Boydton, Virginia. Reputation checks on all 3 IPs returned clean.

The headers show SPF pass, DKIM pass, and DMARC pass, all for gmail.com, and the Return-Path (sonyundefinedralph@gmail[.]com) matches the From address domain. This means the email is not spoofed at the domain level. It was sent from a genuinely authenticated Gmail account. The display name "[BB] - Comunicado ao cliente - Cod. 37165178664887" is therefore a display-name impersonation layered on top of an otherwise legitimate personal Gmail account.

A PDF attachment (Fa0ldxfjHYJ.pdf) was retrieved from the email with the following hashes.

MD5: 73eb1b98ead1ce54c522ef51d42658bc

SHA1: c3d762618ad889d12fc186b1edb437da6a40917c

SHA256: f90e61278e4a12b1f8a89c6620183343354a6fbcd0fdedcb04f44ff16be7cd5b

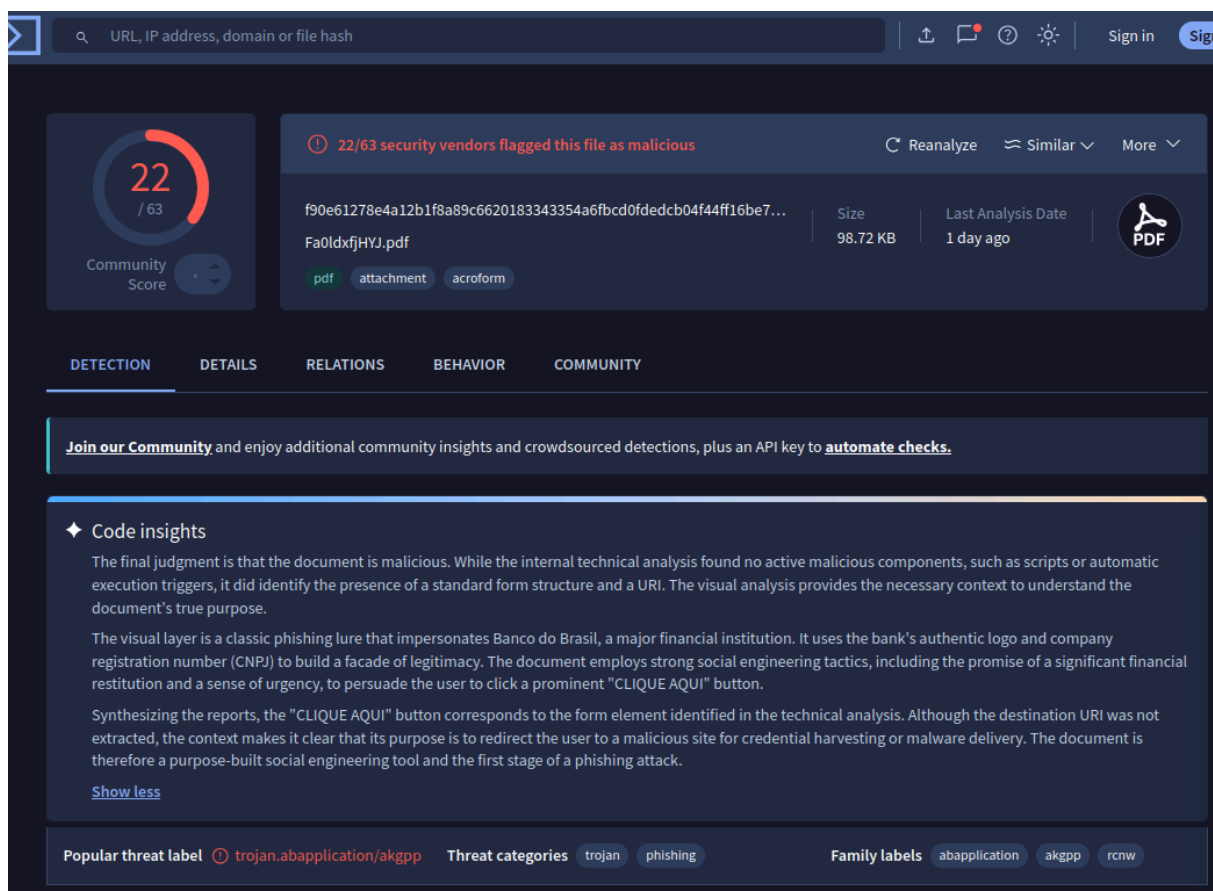
I looked up the attachment's SHA256 hash on VirusTotal.

The screenshot shows the VirusTotal interface for a file analysis. At the top, a search bar contains the SHA256 hash. The file is identified as 'Fa0ldxfjHYJ.pdf' (98.72 KB, analyzed 1 day ago). A circular progress indicator shows a 'Community Score' of 22/63. A red banner states '22/63 security vendors flagged this file as malicious'. Below this, the 'DETECTION' tab is active, displaying 'Code insights' which conclude the document is malicious. A table lists security vendors and their specific detections.

Security vendors' analysis			
AliCloud	Trojan:PDF/Phishing.Akgpp	ALYac	Trojan.GenericKD.76214483
Arcabit	Trojan.Generic.D48AF0D3	Arctic Wolf	Unsafe
Avast	PDF:MalwareX-gen [Phish]	AVG	PDF:MalwareX-gen [Phish]
Avira (no cloud)	PHISH/PDF.Agent	BitDefender	Trojan.GenericKD.76214483

Picture 5. File hash lookup on VirusTotal

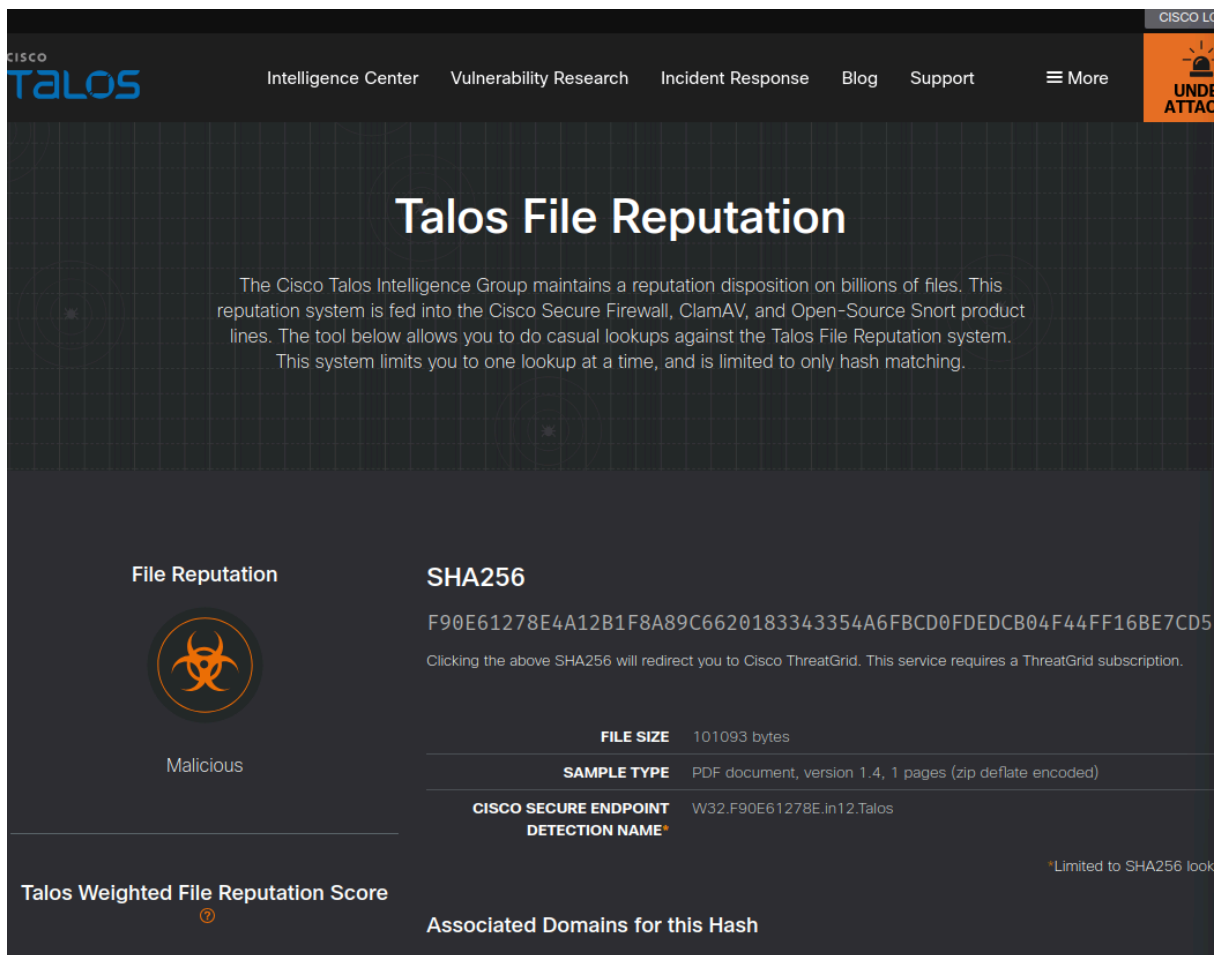
22 out of 63 security vendors flagged this file as malicious, with a popular threat label of trojan.abapplication/akgpp and threat categories of trojan and phishing. VirusTotal's code insights state that the final judgment is malicious.



Picture 6. VirusTotal Summary

VirusTotal's code insights state that the final judgment is malicious, but note that the internal technical analysis found no active malicious components such as scripts or automatic execution triggers. Instead, a standard form structure and a URI, with the visual layer providing the context for the document's true purpose. It also states that the visual layer of the document impersonates Banco do Brasil. The visual layer uses the bank's authentic logo and a company registration number (CNPJ) to build credibility, and employs urgency and the promise of a financial payout to get the recipient to click a prominent "CLIQUE AQUI" (click here) button.

I also checked the file hash on Cisco Talos.



Picture 7. Cisco Talos file reputation

CiscoTalos returns a Malicious verdict, matching VirusTotal. The file is identified as a PDF document, version 1.4, one page, zip-deflate encoded. The file size (101,093 bytes) is consistent with VirusTotal's reported 98.72 KB.

I ran the email file through eml_dump.py to view its MIME structure and extract the attachment.

```
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ python3 ../Tools/emldump.py
sample-1008.eml
1: M      multipart/mixed
2: M      multipart/alternative
3:      285 text/plain
4:      648 text/html
5:      101093 application/pdf (Fa0ldxfjHYJ.pdf)
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ python3 ../Tools/emldump.py
sample-1008.eml -s 5 -d > Fa0ldxfjHYJ.pdf
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ ls
Fa0ldxfjHYJ.pdf sample-1008.eml sample-1042.eml sample-1080.eml sample-1095.eml
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ sha2
sha224sum sha256deep sha256sum
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ sha256sum Fa0ldxfjHYJ.pdf
f90e61278e4a12b1f8a89c6620183343354a6fbcdb04f44ff16be7cd5b Fa0ldxfjHYJ.pdf
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$
```

Picture 8. eml_dump.py output and attachment extraction

The MIME structure shows the email has the attachment in section 5, application/pdf, 101093 bytes, named Fa0ldxfjHYJ.pdf. That byte count matches exactly what Talos reported (101,093 bytes) and lines up with VirusTotal's reported size, confirming this is the same file already analyzed.

I extracted section 5 to a standalone file and ran a SHA256 checksum against it. This matches exactly the hash already submitted to VirusTotal and Talos.

I ran pdf-parser.py against the extracted attachment, searching for /URI objects to identify the embedded link.

```
mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$ python3 ../Tools/pdf-parser.py Fa0ldxfjHYJ.pdf -s "/URI"
/home/mockingcyber/Desktop/Investigations/Phishing/phishing_pot/./Tools/pdf-parser.py:1155: SyntaxWarning: invalid escape sequence '\s'
  print(' oPDF.stream(%d, %d, %s, %s)' % (objectId, object.version, repr(object.Stream(False, options.overridingfilters).rstrip()), repr(re.sub('/Length\s+\d+', '/Length %d', FormatOutput(dataPrecedingStream, True)).strip()))
/home/mockingcyber/Desktop/Investigations/Phishing/phishing_pot/./Tools/pdf-parser.py:1166: SyntaxWarning: invalid escape sequence '\s'
  print(' oPDF.stream(%d, %d, %s, %s)' % (objectId, object.version, repr(object.Stream(False, options.overridingfilters).rstrip()), repr(re.sub('/Length\s+\d+', '/Length %d', FormatOutput(dataPrecedingStream, True)).strip()))
/home/mockingcyber/Desktop/Investigations/Phishing/phishing_pot/./Tools/pdf-parser.py:1643: SyntaxWarning: invalid escape sequence '\d'
  if re.match('PDF-\d\.\d', comment):
This program has not been tested with this version of Python (3.12.3)
Should you encounter problems, please use Python version 3.11.1
obj 6 0
  Type: /Annot
  Referencing:

  <<
  /A
  <<
    /S /URI
    /Type /Action
    /URI (https://iasjdisdji.z13.web.core.windows.net/)
  >>
  /Border [ 0 0 0 ]
  /F 4
  /Rect [ 5.19802 185.02 525 836.722 ]
  /Subtype /Link
  /Type /Annot
  >>

mockingcyber@SOC201:~/Desktop/Investigations/Phishing/phishing_pot$
```

Picture 9. pdf-parser.py output of embedded URI

The link was found in object 6 0 <https://iasjdisdji.z13.web.core.windows.net/web/.core/.windows.net/> is a legitimate Microsoft hosting service frequently abused for phishing pages precisely because the domain itself carries Microsoft's reputation and isn't blocklisted by default. The subdomain "iasjdisdji" is a likely random-looking string with no resemblance to Banco do Brasil, consistent with disposable phishing infrastructure rather than any legitimate banking domain. The destination URL was extracted directly from the PDF's /URI object, but the site is no longer live/resolvable as of the investigation date, so its final payload cannot be directly confirmed. Attempts to retrieve from WaybackMachine were futile as well.

Verdict

This email should be classified as malicious and should not be released to the recipient mailbox.

The email itself passed SPF, DKIM, and DMARC and was sent from a genuinely authenticated gmail.com account (sonyundefinedralph@gmail[.]com), so this is not a case of domain spoofing. The impersonation happens entirely at the display-name level, where the sender presents as "[BB] - Comunicado ao cliente" to impersonate a bank communication. What makes this dangerous is the attachment.

Fa0ldxfjHYJ.pdf carries a 22/63 detection rate on VirusTotal and a Malicious verdict from Cisco Talos, with vendor consensus and code insights identifying it as a phishing document. The PDF's own content confirms this: it visually impersonates Banco do Brasil using the bank's logo and a CNPJ registration number, applies urgency and a false financial-credit pretext, and embeds a full-page clickable link hosted on legitimate but disposable infrastructure. That URL is no longer resolvable as of this investigation, so the actual landing page content (credential harvesting form, further redirect, etc.) could not be directly observed or confirmed. The attack chain in this phish depends on user interaction, i.e. opening the PDF and then clicking the embedded link.

MITRE ATT&CK Mapping

Initial Access — T1566.001 (Phishing: Spearphishing Attachment)

Initial Access / Execution — T1204.001 (User Execution: Malicious Link)

Impersonation -T1656 as defined in ATT&CK v14–v18; in v19 this behavior was folded into the broader Social Engineering in Stealth (T1684) technique.

Indicators of Compromise (IOCs)

Sender Address: sonyundefinedralph@gmail.com

Filename: Fa0ldxfjHYJ.pdf

Hashes:

MD5: 73eb1b98ead1ce54c522ef51d42658bc

SHA1: c3d762618ad889d12fc186b1edb437da6a40917c

SHA256: f90e61278e4a12b1f8a89c6620183343354a6fbcd0fdedcb04f44ff16be7cd5b

Embedded URL: hxxps[:]//]iasjdisdji[.]z13[.]web[.]core[.]windows[.]net/

Sender IP: 209.85.219.43

Recommendations

1. Do not release this email to the recipient. It should remain quarantined and be deleted or moved to a blocked-senders review queue.
2. Block the attachment hash and the embedded URL/domain at the email gateway and web proxy level.
3. If the recipient truly has dealings with Banco do Brasil or Brazilian tax authorities, advise them to verify any tax-credit communications only through the bank's official app or verified domain.
4. Check whether the same sender address, attachment hash, or display-name pattern has targeted other mailboxes, to determine the scope of this campaign.
5. If any user has already opened this attachment and clicked the embedded link, treat it as a potential credential-exposure incident: prompt a password reset on any Banco do Brasil or related financial accounts and monitor for suspicious account activity.